

AI Critique

HW06 — API Testing | SV **Ninh Văn Khải** — **23127060** | Đề bài mục 10 (200–300 từ)

Sai lầm nặng nhất của AI trong bài này không phải viết sai test case, mà là **điền một bảng kiến thức bằng trí nhớ thay vì đọc tài liệu**. Bẫy mã bảo mật SEC-01..07 được AI hiểu theo danh sách lỗ hổng OWASP quen thuộc: SEC-01 là SQL Injection, SEC-05 là leo thang quyền. Bảng thật nói khác hẳn: SEC-01 là mật khẩu không được lưu plaintext, SEC-05 là truy vấn phải dùng parameterized query. Hậu quả: 39/41 test case bảo mật bị gán sai mã.

Đáng chú ý, các test case **vẫn chạy đúng**: một phép thử SQL Injection vẫn là phép thử SQL Injection dù bị dán nhãn sai. Thử hổng là bảng độ phủ trong báo cáo — nó khẳng định API-3 đã phủ SEC-01 với tám test case, trong khi SEC-01 không hề được kiểm ở API-3 dòng nào. Người đọc không thể tự phát hiện loại sai lầm này.

AI không bắt được vì SEC-01 là một **nhãn không tự giải thích**: đọc mã đó không ai đoán được nó nói gì, nên mô hình điền vào bằng liên tưởng mạnh nhất có sẵn. Bảng thật nằm trong README.md của SUT; api_specification.md không chứa bảng nào.

Em cũng mắc lỗi cùng bản chất: chính em viết yêu cầu mỗi API phải phủ đủ bẫy mã SEC. Yêu cầu đó bất khả thi, và cách duy nhất để đạt được là gán bừa.

Nguyên tắc em rút ra: **mọi khẳng định của AI về một định danh — mã yêu cầu, tên trường, hằng số — đều phải đối chiếu với tài liệu gốc trước khi dùng**. AI suy luận tốt trên nội dung, nhưng không đáng tin khi tra cứu định danh, vì nó không phân biệt được nhớ với đoán.